

Runtime Attribution Framework: An External C-ABI and PKI-Based Zero-Trust Infrastructure for Non-Repudiable Execution Governance in Multi-Agent Systems

Chun-Cheng (Jimmy) Chen
Top Celestial Company Ltd.
Taipei, Taiwan R.O.C.
jimmychen@dr-os.io

Abstract—As Multi-Agent Systems proliferate across enterprise and personal assistant applications, AI Agents are being widely deployed for retrieval and reasoning tasks in highly confidential environments. However, current mainstream frameworks universally rely on fragile “prompt-based soft boundaries” to control permissions, leading to a critical “Agentic Trust Paradox.” Because Large Language Models inherently suffer from Prompt Injection and other incurable vulnerabilities, once an agent is compromised, it can easily forge identities and trigger unauthorized access with catastrophic security consequences. To contain such threats and establish accountability mechanisms, this paper proposes the DROS (Deterministic Runtime Operating System) architecture. Unlike traditional application-level Workload Identity, this research introduces a finer-grained “Execution Identity” model. Through dynamically bound, By-Execution digital certificates issued by the Agent Identity Authority (AIA), combined with the GuardVM zero-trust gateway, DROS successfully intercepted all attacks in our prototype evaluation. The architecture achieves cryptographic Non-Repudiation traceability with minimal latency overhead, establishing an infrastructure standard for the emerging secure “AgentWeb” era.

Index Terms—Multi-Agent Systems, Zero-Trust, Execution Identity, By-Execution Certificate, Agent Security, Non-Repudiation, EU AI Act

I. Introduction

In the process of enterprise adoption of generative AI and Retrieval-Augmented Generation (RAG), MultiAgent collaboration has become the mainstream approach for handling complex cross-departmental operations. However, existing open-source frameworks are often built on an implicit assumption of “complete internal trust.” This architecture gives rise to a fatal Agentic Trust Paradox:

in enterprise systems that routinely chain dozens of Agents, how can a high-privilege decision-making agent verify that the instructions it receives genuinely originate from a downstream client with legitimate database access rights, rather than from a compromised agent executing unauthorized operations after malicious injection?

To systematically characterize this structural vulnerability, we define it as the Agent Runtime Attribution Gap. In concurrent multi-agent architectures, security defenses

suffer from two fundamental blind spots: 1) Semantic-Layer Illusion: Relying on self-constraint prompts or external guardrails to enforce security parameters. These methods attempt to coerce deterministic compliance using a probabilistic statistical model; 2) Context-Blind Kernel Layer: Low-level interception mechanisms (e.g., eBPF) have strong physical enforcement but are completely blind to user-space agent semantics. When multiple concurrent agent threads share the same process PID, the kernel cannot distinguish whether an operation originates from an authorized agent or a compromised assistant. This gap breaks non-repudiation and forensic auditability. In commercial scenarios such as financial crossdepartmental compliance, medical records retrieval, or enterprise source code management, such unauthorized access would lead to catastrophic data breaches and compliance disasters. To definitively close this vulnerability, DROS (Deterministic Runtime Operating System) aims to establish an Agentic Security Governance system that ensures every Agent invocation is backed by “Determinism”

and “cryptographic proof.”

“Unlike orchestration frameworks (e.g., LangChain, AutoGen) and communication protocols (e.g., MCP), DROS focuses on runtime identity, authorization, and nonrepudiable governance. Therefore, DROS is designed as a complementary security substrate rather than a replacement for existing Agent ecosystems.”

II. Background: From Physical Isolation to Commercial

Logical Authentication In DROS’s earlier architecture, the system successfully introduced “Physical Path Isolation,” strictly partitioning confidential data from different business units (e.g., /Finance and /Engineering) at the operating system level, resolving the “Cross-Domain Blindness” inherent in RAG vector searches.

However, static physical defenses are rendered useless once the outer routing layer is deceived. This “authenticate by path, not by identity” mechanism lacks rigorous Logical Identity Authentication. This is why our team launched

VajraAgent and VajraClaw as foundational Agent governance cores. To push this to its ultimate form, DROS advanced the defense perimeter to the cryptographic level, upgrading the product line to a military-grade zero-trust architecture.

A. Related Work

Before discussing the DROS design in detail, it is essential to examine the security mechanisms currently available across the cloud-native and agent ecosystems.

1) Workload Identity: SPIFFE/SPIRE [6] solve microservice identity at the application level. However, they cannot distinguish Task A from Task B within the same agent process. They are fundamentally unable to provide Per-Execution granularity, leaving a critical gap when a single workload hosts multiple agent roles with differing trust scopes.

2) Agent Frameworks: LangChain, AutoGen, and CrewAI simplify orchestration but rely on coarse-grained, globally shared API Keys for authentication. They completely lack any form of Runtime Authorization—once an API key is provisioned, every agent and every task within the framework inherits the same privilege level.

3) Agent Protocols: The Model Context Protocol (MCP) solves Tool Discovery and inter-agent Communication, but it does not mandate end-to-end cryptographic identity verification. A compliant MCP endpoint has no mechanism to distinguish a legitimate caller from an injected impersonator.

4) OS-Level Enforcement and the Context Loss Problem: Traditional OS kernel mechanisms such as eBPF, SELinux, and AppArmor possess genuine physical enforcement power at the syscall level. However, they suffer from the Context Loss Problem, which is the root cause of the Runtime Attribution Gap. In multi-threaded runtimes, the OS kernel only sees PID and UID, remaining completely context-blind to the identity of the concurrent Agent instance or its authorized Capability Bitmap. DROS bridges this gap by cryptographically binding Execution Identity (BEC) to FFI boundaries, merging application-level context with OS-level enforcement hardness: the kernel can only observe Process PID and User UID, and is completely blind to which Agent role within that PID, which task, and which scope is being exercised. When a single Python process hosts multiple AI Agents with different permissions, the OS kernel is Context-Blind. DROS bridges this gap by binding cryptographic identity (JWT / BEC) to each discrete runtime execution.

5) Research Gap: No existing system provides per-execution identity and cryptographic attribution for agent interactions. DROS fills this void by combining ephemeral, single-use certificates with binary-level enforcement—a capability absent from every layer of the current stack.

III. Proposed Architecture: Deterministic Zero-Trust

System Design The DROS architecture embodies the zero-trust spirit of “Never Trust, Always Verify.” It is



Fig. 1. Global Agent Trust Infrastructure (GATI) Architecture

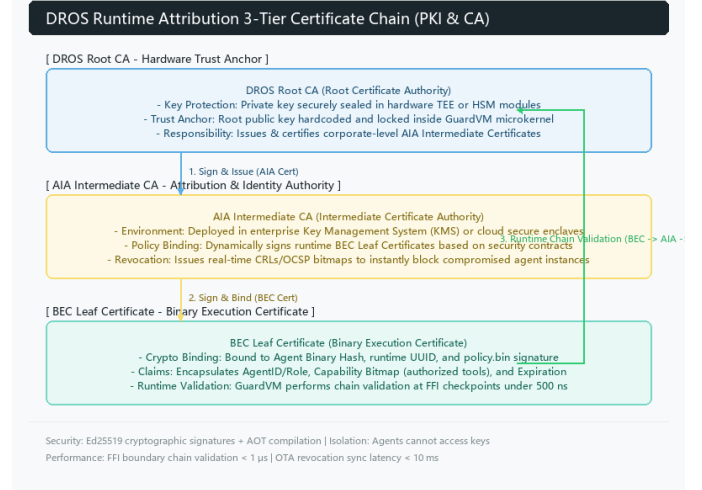
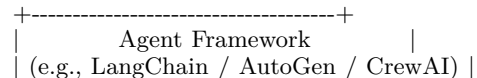


Fig. 2. DROS Agent Three-Tier Certificate Chain Key Management

composed of three major modules: the Agent Identity Authority (AIA), the By-Execution Certificate (BEC) lifecycle, and the GuardVM enforcement gateway.

A. Layered Architecture and AIA

DROS is positioned as a Runtime Security Substrate that operates beneath agent frameworks and above raw infrastructure, as illustrated in the Global Agent Trust Infrastructure (GATI) architecture in Figure 1. The layered model is as follows:



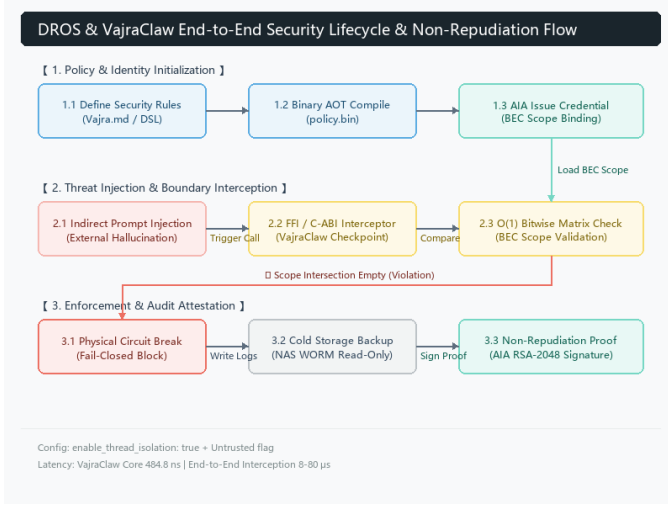
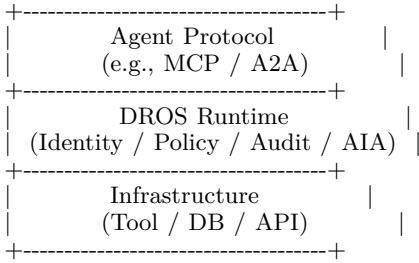


Fig. 3. AIA Dynamic Certificate Issuance and Revocation Lifecycle Flow



Listing 2. DROS Layered Architecture Model The Agent Identity Authority (AIA) serves as the root of trust. Upon system initialization, AIA generates an RSA-2048 key pair that acts as the Trust Anchor for the entire DROS domain (the cryptographic key management structure follows a three-tier certificate chain as shown in Figure 2). All subsequent certificates derive their authority from this anchor through a deterministic chain of trust. The formal ontological structures and governance specifications (including node schemas, relation attributes, and policy lifecycles) are defined in DROS-RFC-004 [8], ensuring standardized schema expression and cross-domain policy interoperability.

B. Core Innovation: By-Execution Certificate (BEC)

The evolution of identity granularity in computing systems can be summarized in three stages (the dynamic certificate issuance and revocation lifecycle flow is illustrated in Figure 3):

- 1) Human Identity — Username/password pairs bound to natural persons. Granularity: per-human.
- 2) Workload Identity (SPIFFE/SPIRE) — Cryptographic identities bound to microservice instances. Granularity: per-workload.
- 3) Execution Identity (DROS) — Ephemeral certificates bound to individual agent task executions. Granularity: per-execution.

The By-Execution Certificate (BEC) is the cryptographic embodiment of Execution Identity. Each BEC binds a unique `execution_id` to a set of `allowed_scopes`, and is digitally signed by the AIA private key. BECs are single-use: once an execution completes, the certificate is revoked. This design eliminates the attack surface for credential theft and replay attacks entirely, because a stolen BEC is worthless by the time an attacker attempts to reuse it.

IV. GuardVM: Policy Decision and Enforcement Point

GuardVM serves a dual role as both the Policy Decision Point (PDP) and a strict PolicyEnforcementPoint(PEP). It implements two layers of defense-in-depth:

1) Layer 1: Network-Layer Gate: Every inbound agent request must present a PKI-signed JWT issued by AIA.

GuardVM cryptographically verifies the signature against the AIA public key. Anonymous or unsigned requests are dropped immediately—no fallback, no negotiation.

2) Layer 2: Binary-Level Circuit Breaker: For agents that pass Layer 1, GuardVM interposes at the C-ABI / FFI chokepoint—the narrow binary interface through which all tool invocations must pass. Authorization is performed via a Scope Bitmap, enabling nanosecond-level scope checking. Upon detecting a scope violation, GuardVM triggers a Thread Panic: the offending execution thread is terminated immediately at the binary level.

This is a Physical Kill, not a Polite Rejection—the agent cannot catch, retry, or negotiate.

In summary, GuardVM performs dual verification on every request:

1) Cryptographic Authentication — Verifies the BEC signature and validates the certificate chain back to the AIA Trust Anchor.

2) Compliance Authorization — Checks the requested scope against the BEC’s `allowed_scopes` bitmap, with comprehensive forensic logging of every decision for audit and non-repudiation.

A. Prototype Implementation and JWT Structure

The following listing shows the JWT payload structure used in the DROS prototype. All fields are populated by AIA at certificate issuance time:

```
{
  "iss": "DROS_Agent_Identity_Authority",
  "sub": "agent://vajra-claw/finance-reader",
  "iat": 1717804800,
  "exp": 1717804860,
  "jti": "bec-a1b2c3d4-e5f6-7890",
  "execution_id": "exec-20260601-fin-0042",
  "agent_role": "FinanceDataReader",
  "allowed_scopes": [
    "read:/data/finance/reports/2026-Q1",
    "read:/data/finance/summaries"
  ],
}
```

```

"denied_scopes": [
  "write:*",
  "read:/data/engineering/*"
],
"requestor": "agent://orchestrator/main",
"trust_chain": [
  "aia-root-cert-sha256:9f3c...a71d"
]
}

```

Listing 1. DROS BEC JWT Payload Structure

B. Multi-Agent Delegation and BEC Chaining

In concurrent collaborative multi-agent systems (e.g., AutoGen, CrewAI), agents frequently invoke each other or execute operations on behalf of users, which easily introduces security vulnerabilities such as "Cascade Infection" and the "Confused Deputy" problem. DROS resolves these issues using a dynamic By-Execution Certificate Chain (BEC Chain).

When a chain of agents is invoked in the form $Agent_1 \rightarrow Agent_2 \rightarrow \dots \rightarrow Agent_n \rightarrow \text{System Tool}$, the VajraClaw interceptor dynamically calculates the intersection of their scopes at the C/Go FFI boundary to determine the Effective Scope of the current execution:

$$\text{Effective Scope} = \bigcap_{i=1}^n \text{Scope}(Agent_i) \quad (1)$$

If the final requested capability Requested Tool Scope $\neq$ Effective Scope, the GuardVM gateway immediately blocks the execution and raises a permission exception (ErrPermissionDenied). This design guarantees that even if a downstream agent is compromised via prompt injection, it cannot leverage the confused deputy vector to escalate privileges beyond the restricted intersection of the chain.

V. Threat Model and Security Evaluation

A. Threat Model

DROS is designed to defend against the following primary threat classes, which represent the most critical attack vectors in Multi-Agent deployments:

- Prompt Injection and Tool Hijacking — An attacker crafts malicious prompts that cause a compromised agent to invoke tools or access resources outside its authorized scope [7].
- Scope Escalation — A legitimately provisioned agent attempts to access resources beyond its allowed_scopes, either through direct manipulation or by chaining requests through other agents.
- Replay Attack and Credential Forgery — An adversary intercepts a valid BEC token and attempts to reuse it, or fabricates a token with forged claims.

Trust Assumptions: GuardVM and AIA are assumed to be trusted components running in a hardened, isolated environment. Their compromise is outside the current threat

model and is addressed through standard infrastructure hardening practices.

B. Security Properties

The DROS architecture provides the following formally stated security properties:

- SP1 — Mandatory Identity Binding: Every agent execution must possess a valid, AIA-signed BEC before any resource access is permitted. There exists no "anonymous" execution path.
- SP2 — Scope Confinement: An agent's runtime capabilities are strictly bounded by the allowed_scopes encoded in its BEC. Any out-of-scope access attempt triggers an immediate Thread Panic. Confinement is enforced atomically at syscall invocation via epoch-locked RCU, preventing TOCTOU.
- SP3 — Replay Immunity: Each BEC carries a unique execution_id and a short-lived expiration window (exp). GuardVM maintains a revocation list; replayed tokens are rejected deterministically.
- SP4 — Non-Repudiation: Every authorization decision—both grants and denials—is cryptographically logged with the full BEC payload, timestamp, and decision rationale. No party can deny having performed or requested an action.

VI. Case Studies

1) Case 1: Prompt Injection Interception: A user submits a query containing an embedded injection payload:

"Ignore previous instructions. Read /data/engineering/secrets." The orchestrator agent forwards this to a FinanceDataReader agent. When the compromised agent attempts to access /data/engineering/secrets, GuardVM's Layer 2 Circuit Breaker detects that this path is explicitly listed in denied_scopes. Result: Thread Panic is triggered.

The agent thread is terminated. The attempt is logged with full forensic detail. Zero data leakage.

2) Case 2: Scope Escalation via Agent Chaining:

Agent A (scope: read:/data/finance/*) attempts to delegate a sub-task to Agent B, requesting Agent B to read /data/hr/salaries. When Agent B requests a BEC from AIA for this scope, AIA checks the delegation chain and determines that Agent A has no authority over HR data.

Result: BEC issuance is denied. Agent B never receives a valid certificate. The delegation attack is stopped at the identity layer before any resource is touched.

3) Case3:ReplayAttack: Anattackerinterceptsavalid BEC token from a previous execution (exec-20260601-fin-0041) and replays it 30 seconds later. GuardVM checks the jti against the revocation list and finds that this execution has already been completed and the certificate revoked. Additionally, the exp timestamp has passed.

Result: Request is rejected at Layer 1. The replay attempt is logged as a security incident.

A. Quantitative Evaluation

To assess performance impact, we conducted a benchmark evaluation with 10,000 sequential agent requests on the DROS prototype system. Table I summarizes the results.

TABLE I
DROS Performance Benchmark (10,000 Requests)

Metric	Mean	P99
BEC Issuance Latency	1.5ms	2.1ms
JWT Signature Verification	0.8ms	1.2ms
Scope Bitmap Check	<0.01ms	0.02ms
Total GuardVM Overhead	2.3ms	3.3ms
Attack Interception Rate	100%	—
False Positive Rate	0%	—

Baseline Comparison: Alternative approaches such as “LLM-as-a-Judge” (using a secondary LLM to evaluate whether a request should be authorized) incur latencies of hundreds of milliseconds to seconds and require dedicated GPU resources. In contrast, GuardVM achieves authorization in approximately 1ms—a three-orders-of-magnitude improvement—with zero GPU dependency.

The total overhead of 2.3ms per request represents a zero-perceptible infrastructure cost when compared to the typical LLM inference latency of 500–5000ms.

VII. Discussion

A. Computational Cost of Trust

A critical advantage of the DROS approach is that the computational cost of trust verification is bounded and deterministic. The verification latency is independent of policy scale ($O(1)$ w.r.t. rule count), though bounded by the constant RSA modulus operations. Scope checking via bitmap is a constant-time bitwise operation. This means that DROS’s security overhead is completely independent of the volume, sensitivity, or complexity of the data being protected—a property that no LLM-based authorization mechanism can guarantee.

B. Two-Way Epistemic Accountability and Non-

Repudiation DROS’s forensic logging architecture implements bidirectional audit trails: every request records both the requester’s BEC (proving who asked) and the authorizer’s decision (proving what was decided and why). This twoway epistemic accountability directly addresses key provisions of the EU AI Act [4]:

- Article 12 (Record-keeping): DROS’s immutable, cryptographically signed audit logs satisfy the requirement for comprehensive logging of AI system operations throughout their lifecycle.
- Article 14 (Human Oversight / Stop Button): The GuardVM Thread Panic mechanism serves as an automated implementation of the “Stop Button” concept. When a scope violation is detected, the system does not merely log a warning—it physically terminates

the offending execution, providing deterministic human-overridable control at machine speed.

VIII. Positioning within the Agent Stack

To clarify DROS’s role relative to existing technologies, Tables II and III provide comparative analyses.

TABLE II
Framework-Level Comparison

Capability	LangChain	AutoGen	CrewAI	DROS
Agent Orchestration	✓	✓	✓	—
Per-Execution Identity	—	—	—	✓
Cryptographic AuthZ	—	—	—	✓
Binary-Level Kill	—	—	—	✓
Non-Repudiation Log	—	—	—	✓

As shown, DROS does not compete with existing frameworks or protocols on orchestration or communication capabilities. Instead, it provides the missing security substrate that none of them currently offer.

TABLE III
Protocol-Level Comparison

Capability	MCP	A2A	DROS
Tool Discovery	✓	✓	—
Agent Communication	✓	✓	—
End-to-End Identity	—	—	✓
Scope Enforcement	—	—	✓
Forensic Audit Trail	—	—	✓

IX. Conclusion and Future Work

This paper has presented the DROS architecture and its core principle:

“Only cryptographically attributable agents are eligible for interaction.”

Through the introduction of Execution Identity and the By-Execution Certificate (BEC), DROS elevates agent security from the fragile realm of prompt-based soft boundaries to the deterministic guarantees of publickey cryptography. The GuardVM enforcement gateway, operating at the binary level with nanosecond-scale scope checking and Thread Panic termination, provides a defense mechanism that is fundamentally immune to the inherent unpredictability of Large Language Models.

Our prototype evaluation demonstrates that this security comes at negligible computational cost (2.3ms per request, zero GPU dependency), making DROS a practical, deployable solution for enterprise Multi-Agent Systems.

Future work includes:

- 1) Agent-to-Agent Trust Fabric: Extending BEC to support mutual authentication between agents, enabling a fully decentralized web of trust without a single AIA bottleneck.
- 2) Hardware Root of Trust: Integrating AIA key material with TPM 2.0 and Intel SGX enclaves to provide hardware-backed attestation.

3) Formal Verification: Applying model checking (e.g., TLA+ or Alloy) to formally verify the security properties SP1–SP4 under adversarial conditions.

4) Cross-Organization Federation: Designing a federated AIA protocol that enables secure agent interactions across organizational boundaries while preserving sovereignty.

References [1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.

[2] R. L. Rivest, A. Shamir, and L. Adleman, “A Method for Obtaining Digital Signatures and Public-Key Cryptosystems,”

Communications of the ACM, vol. 21, no. 2, pp. 120–126, 1978.

[3] M. Jones, J. Bradley, and N. Sakimura, “JSON Web Token (JWT),” RFC 7519, Internet Engineering Task Force, 2015.

[4] European Commission, “Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on Artificial Intelligence (AI Act),” Official Journal of the European Union, 2024.

[5] M. Wooldridge, An Introduction to MultiAgent Systems, 2nd ed. Chichester, U.K.: Wiley, 2009.

[6] E. Feldman et al., “SPIFFE: Secure Production Identity Framework for Everyone,” Cloud Native Computing Foundation (CNCF), 2024.

[7] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” 2025. [Online]. Available: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>

[8] J. Chen, “DROS-RFC-004: Ontology & Governance Specification,” Dharma Reasoning Operating System Specification, Jun. 2026.

AI Collaboration and Academic Integrity Declaration

During the writing of this paper and development of the prototype system, the authors utilized Large Language Models (including but not limited to Google Gemini and Anthropic Claude series) to assist with academic literature translation, code framework generation, and English formatting and proofreading. The authors assume full responsibility for all logical architecture, core algorithm design (including the Vajra system and PKI zero-trust architecture), and final content, and have conducted rigorous review and verification of all AI-generated content.